



Post-Incident Analysis

1. Introduction

Post-incident analysis is a critical phase in the incident response lifecycle. While containment and remediation stop immediate threats, long-term security improvement depends on understanding why the incident occurred and how similar incidents can be prevented in the future.

This report demonstrates structured post-incident analysis using Root Cause Analysis (RCA), the 5 Whys methodology, Fishbone analysis, and SOC performance metrics including Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR). The methodology aligns with guidance from **National Institute of Standards and Technology SP 800-61 (Computer Security Incident Handling Guide)**.

2. Incident Overview

Incident Type: Phishing-based credential compromise.

Summary: A phishing email bypassed email filtering mechanisms. A user clicked a malicious link, leading to credential harvesting and unauthorized login attempts.

The incident was detected within 2 hours and contained within 4 hours.

3. Root Cause Analysis (RCA)

Root Cause Analysis identifies the underlying reasons behind an incident rather than focusing only on symptoms.

3.1 5 Whys Method

The “5 Whys” technique systematically asks why an issue occurred until the root cause is identified.

Question	Answer
Why was the email opened?	The user clicked a malicious link.
Why was the link clicked?	The email appeared legitimate.
Why did it appear legitimate?	Email filtering failed to flag it.
Why did filtering fail?	No advanced phishing detection rules were configured.



Why were advanced rules missing?	Security configuration review was not updated regularly.
----------------------------------	--

Root Cause Identified:

Lack of advanced email security configuration and insufficient periodic security review.

4. Fishbone Diagram (Cause & Effect Analysis)

A Fishbone (Ishikawa) analysis categorizes causes into structured domains.

Main Categories Identified:

1. People:
 - Lack of user awareness training.
 - User unable to identify phishing indicators.
2. Process:
 - No regular phishing simulation exercises.
 - No mandatory reporting workflow.
3. Technology:
 - Weak email filtering configuration.
 - No advanced sandboxing for attachments.
4. Policy:
 - Infrequent security audits.
 - Lack of strict privilege escalation review.

This structured breakdown helped identify both technical and human factors contributing to the incident.

5. SOC Performance Metrics

Measuring SOC performance ensures continuous improvement.

5.1 Mean Time to Detect (MTTD)

MTTD measures how long it takes to detect an incident after compromise.

Formula: Detection Time – Initial Compromise Time

- Initial compromise: 10:00 AM
-



- Detection: 12:00 PM

MTTD = 2 hours

5.2 Mean Time to Respond (MTTR)

MTTR measures how long it takes to contain and remediate after detection.

- Detection: 12:00 PM
- Containment: 4:00 PM

MTTR = 4 hours

Performance Interpretation

- Detection time was reasonable.
 - Response time showed room for automation improvement.
 - Phishing filtering improvements needed.
-

6. Continuous Improvement Plan

Based on analysis, the following improvements are recommended:

Technical Improvements

- Deploy advanced phishing detection rules.
- Enable attachment sandboxing.
- Implement strict DMARC, DKIM, SPF policies.
- Enforce multi-factor authentication (MFA).

Process Improvements

- Conduct quarterly phishing simulations.
- Establish mandatory reporting workflow.
- Perform periodic configuration audits.

Training Improvements

- Conduct employee phishing awareness training.
 - Simulated phishing drills.
-



7. Improvement Summary

The phishing incident occurred due to weak email filtering and insufficient configuration review processes. Root Cause Analysis revealed gaps in both technical controls and user awareness. Improvements including advanced filtering, MFA enforcement, periodic audits, and employee training will significantly reduce the likelihood of similar incidents in the future.

8. Key Learnings

- Post-incident analysis strengthens SOC maturity.
 - Root Cause Analysis prevents recurrence.
 - Metrics such as MTTD and MTTR measure effectiveness.
 - Continuous improvement requires both technical and procedural enhancements.
 - Human factors play a major role in phishing incidents.
-

9. Conclusion

This post-incident analysis successfully identified the underlying causes of a phishing-based credential compromise using structured RCA techniques. By applying the 5 Whys methodology and performance metrics, both technological and procedural gaps were identified. Continuous improvement measures were proposed to enhance detection capabilities, strengthen response time, and reduce overall incident risk in the future.